DORA FRB HKMA PRA MAS

FINANCIAL RESILIENCE SCOPING ENGINE

Strategic Nexus

Global Regulated Enterprise (DORA, FRB, HKMA, PRA, MAS, APRA, NYDFS)
Threat-Led Penetration Testing Scoping Document — Nexus v33.0

ENTITY	RESILIENCE INDEX	ENGAGEMENT DURATION	CLASSIFICATION
Global Apex Bank	100%	70 Days	Restricted

Financial Resilience Coverage Index

10

TLPT RESILIENCE INDEX

Financial Resilience Coverage Score

This score reflects the breadth of coverage across the four mandatory Threat-Led Penetration Testing pillars required under DORA Article 26, PRA CBEST, and HKMA iCAST.

TLPT COMPLIANCE PILLAR	COVERAGE STATUS
Threat Intelligence Profiling	VALIDATED
Covert Attack Emulation	VALIDATED
Purple Team Collaboration	VALIDATED
Executive Crisis Validation	VALIDATED

Executive Resourcing & Schedule Summary

Executive Resourcing & Schedule Summary

The following summarizes the operational timeline and resourcing required to execute the defined Threat-Led Penetration Testing modules in alignment with regulatory mandates.

70
TOTAL ENGAGEMENT DAYS

14
EXECUTION WEEKS

4
TLPT PERSONNEL

4
ACTIVE MODULES

Automated TLPT Resourcing Allocation

ROLE	HEADCOUNT	TLPT RESPONSIBILITY	CLEARANCE
Threat Intel & Red Team Lead	1	Strategic oversight, regulatory coordination, TI report authorship, and final QA gate review.	Full Knowledge
Covert Red Team Operator	3	Technical execution, assumed breach operations, exploit development, and stealth persistence.	Full Knowledge
Purple Team Facilitator	1	Replay exercise facilitation, SOC detection tuning, and SIEM rule validation.	Full Knowledge
Client White Team	TBD	Kill-switch authority, CBS owner coordination, and regulatory notification.	Full Knowledge

1.5 Regulatory Alignment: Global Regulated Enterprise (DORA, FRB, HKMA, PRA, MAS, APRA, NYDFS)

Narrative: A unified global compliance scoping document consolidating DORA, FRB, HKMA, PRA, and MAS requirements.

REGULATORY BODY

Digital Operational Resilience Act (DORA) (European Union)

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
Article 5	ICT Risk Management Framework	Firms must maintain a comprehensive, documented ICT risk management framework reviewed at least annually.	All critical ICT systems underpinning core financial functions.
Article 9	Protection & Prevention	Continuous monitoring and safeguarding of ICT systems; anomaly detection and prevention controls.	SIEM / SOC controls and detection capabilities under covert Red Team conditions.
Article 11	Business Continuity & Disaster Recovery	Firms must implement and test BCPs and DR plans for all critical functions.	RTO/RPO objectives tested via Purple Team replay and IR tabletop exercises.
Article 24	General ICT Testing Programme	Annual ICT resilience testing programme with risk-based scope.	All critical ICT systems and third-party ICT providers.
Article 26	Threat-Led Penetration Testing (TLPT)	Advanced TLPT required every 3 years for major financial entities. Mandates intelligence-led, covert, scenario-based Red Team testing.	Qualified external Red Team with regulatory oversight. TI-PHASE must precede RT-COVERT.
Article 28	ICT Third-Party Risk Management	Contractual obligations and exit strategies must be defined for all critical ICT third-party providers.	Cloud workloads, payment processors, and external ICT dependencies.
Article 30	Key Contractual Provisions	Contracts with ICT third parties must define SLAs, audit rights, and regulatory access provisions.	All contractual frameworks with critical ICT third-party service providers.

Mandatory Evidence Artifacts:

- Asset Register & CBS Map
- ICT Risk Register
- Threat Intelligence Profile
- TLPT Test Plan (Pre-Execution)
- TLPT Execution Report
- Remediation Plan & Timeline
- Third-Party ICT Risk Assessment

IMPLEMENTATION GUIDANCE

DORA

ICT Asset Criticality Mapping

Under DORA, scoping must start with the ICT Asset Register. Every asset in scope must be mapped to a 'Critical or Important Function' (CIF). If an asset supports a CIF, it is subject to more rigorous testing and reporting requirements.

Third-Party ICT Risk

DORA requires that testing includes third-party ICT service providers where they support critical or important functions. This scoping pack must include a list of involved third parties and confirmation of their authorization to test.

Threat Intelligence Requirements

For TLPT (Threat-Led Penetration Testing), the scope must be driven by current, relevant threat intelligence. The scenarios defined in this pack should match the TTPs of actors targeting the financial sector.

REGULATORY BODY

Federal Reserve Board (FRB) Supervision (United States)

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
SR 13-1	Supplemental Policy Statement on the Internal Audit Function	Independent testing and validation of technology risk controls. Audit function must be independent and objective.	Risk-based coverage of all material technology and cybersecurity controls.
SR 11-7	Guidance on Model Risk Management	Models used in risk decision-making must be subject to rigorous validation and independent testing.	AI/ML fraud detection models and algorithmic trading controls.
CAT	Cybersecurity Assessment Tool (CAT)	Institutions must assess their cybersecurity maturity against the FFIEC CAT framework.	Baseline controls, evolving controls, and innovative controls across all technology domains.

Mandatory Evidence Artifacts:

- Independent Technology Review Report
- Management Response & Remediation Plan
- Prior Findings Remediation Evidence
- FFIEC CAT Baseline Assessment

IMPLEMENTATION GUIDANCE

FRB

SR 13-1 / Vendor Risk

The scoping must encompass critical third-party vendors and external facing infrastructure in alignment with FRB supervision expectations.

REGULATORY BODY

Hong Kong Monetary Authority (HKMA) iCAST (Hong Kong)

STRICTLY CONFIDENTIAL // STRATEGIC SCOPE

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
CFI 2.0 – Pillar 1	Cybersecurity Assessment Framework (CAF)	Institutions must conduct a CAF self-assessment to determine their cybersecurity maturity level.	All critical systems and business functions serving retail and institutional clients.
CFI 2.0 – Pillar 2	Intelligence-led Cyber Attack Simulation (iCAST)	Perform controlled, covert, intelligence-led simulated attacks on live production systems.	Threat intelligence-derived simulation targeting CBS with systemic financial impact.
CFI 2.0 – Pillar 3	Cybersecurity Ecosystem Development	Contribution to the Hong Kong financial sector cybersecurity ecosystem and information sharing.	Participation in HKMA Cyber Intelligence Sharing Platform (CISP) post-engagement.

Mandatory Evidence Artifacts:

- CAF Self-Assessment Report
- Threat Intelligence Profile (TI-PHASE Output)
- iCAST Execution Log
- Closure Report & Control Effectiveness Summary
- Remediation Plan

IMPLEMENTATION GUIDANCE

HKMA

iCAST Execution

Simulations must cover the 'Assume Breach' methodology to assess the detection and response capabilities of the institution's Security Operations Center (SOC).

Prudential Regulation Authority (PRA) CBEST (United Kingdom)

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
CBEST – Phase 1	Threat Intelligence Assessment	Commission an independent Threat Intelligence assessment from a CREST-certified provider to define the threat landscape.	Identification of Threat Actor profiles, TTPs, and targeted Critical Business Services (CBS).
CBEST – Phase 2	Penetration Testing	Execute a covert, intelligence-led penetration test against the CBS identified in Phase 1.	CREST-certified Red Team with FCA-registered status. Zero knowledge for Blue Team.
CBEST – Phase 3	Remediation & Closure	Produce a Closure Report documenting findings, remediation actions, and control effectiveness.	Submitted to PRA/FCA within agreed timelines. Regulator retains right of review.
STAR-FS	Systematic Technical Assurance Review	A broader assessment framework for FMIs incorporating CBEST methodology with systemic risk focus.	Financial Market Infrastructures (FMIs) including payment systems and CCPs.

Mandatory Evidence Artifacts:

- Targeted Threat Intelligence Report (TTIR)
- CBEST Test Plan
- Red Team Execution Report
- Control Effectiveness Summary
- Closure Report (PRA/FCA Submission)

IMPLEMENTATION GUIDANCE

PRA

CBEST Intelligence-Led Testing

Testing must be driven by bespoke threat intelligence targeting the specific critical business services (CBS) of the UK financial institution.

REGULATORY BODY

Monetary Authority of Singapore (MAS) TRM (Singapore)

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
TRM Section 9	Cyber Risk Management	Institutions must establish a robust cyber risk management framework with Board-level oversight.	Board-level reporting on cyber risk and TLPT results mandatory.
TRM Section 12	Vulnerability Assessment and Penetration Testing (VAPT)	Conduct comprehensive VAPT on all critical IT systems annually or upon major system changes.	All internet-facing applications, core banking platforms, and payment APIs.
TRM Section 13	Cyber Incident Response & Management	Simulate adversary attacks to test the detection, containment, and recovery capabilities of the institution.	Red team exercises for major institutions. Incident response plan must be tested at least annually.
Notice MAS 655	Cyber Hygiene Baseline	Mandatory baseline cyber hygiene measures including network segmentation, patching, MFA, and logging.	Technical controls audit and validation as part of Red Team execution scope.

Mandatory Evidence Artifacts:

VAPT Report | Red Team Execution Log | Root Cause Analysis Report | Remediation Status Register | Board Cyber Risk Report

IMPLEMENTATION GUIDANCE

MITRE

T1190 - Exploit Public-Facing Application

Adversaries may attempt to take advantage of a weakness in an Internet-facing computer or program using software, data, or commands in order to cause unintended or unanticipated behavior.

T1078 - Valid Accounts

Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion.

T1566 - Phishing

Adversaries may send phishing messages to gain access to victim systems. All forms of phishing are electronically delivered social engineering.

T1059 - Command and Scripting Interpreter

Adversaries may abuse command and script interpreters to execute commands, scripts, or binaries.

IMPLEMENTATION GUIDANCE

OWASP

A01:2021-Broken Access Control

Testing must validate that users cannot act outside of their intended permissions. Failures typically lead to unauthorized information disclosure, modification, or destruction of all data.

A02:2021-Cryptographic Failures

Testing must verify the protection of sensitive data in transit and at rest. This includes passwords, credit card numbers, health records, personal information, and business secrets.

A03:2021-Injection

Testing must validate that user-supplied data is not interpreted as commands or queries (e.g., SQL, NoSQL, OS command, ORM, LDAP, and EL expression or OGNL injection).

A04:2021-Insecure Design

Testing must evaluate the architectural design for missing or ineffective control design. Insecure design cannot be fixed by a perfect implementation.

IMPLEMENTATION GUIDANCE

CIS

Control 1: Inventory and Control of Enterprise Assets

Actively manage (inventory, track, and correct) all enterprise assets connected to the infrastructure physically, virtually, remotely, and those within cloud environments.

Control 4: Secure Configuration of Enterprise Assets and Software

Establish and maintain the secure configuration of enterprise assets and software.

Control 12: Network Infrastructure Management

Establish, implement, and actively manage network devices, in order to prevent attackers from exploiting vulnerable network services and access points.

Threat Scenarios & Modeling

Threat Intelligence Profiles

The following threat actors and attack scenarios have been selected to drive the execution methodology.

THREAT ACTOR	MOTIVATION	TARGET OBJECTIVE	PRIMARY TTPS
APT-FIN7 / Carbanak	Financial Crime â€“ Fraudulent SWIFT Transfers	Compromise SWIFT operator credentials and initiate fraudulent payments	Spearphishing, Credential Harvesting, LOTL, SWIFT API Abuse
APT-Lazarus Group	State-Sponsored â€“ Capital Generation	Lateral movement to core banking and treasury systems	Supply Chain Compromise, Watering Hole, Custom Malware Implants
Ransomware-as-a-Service (RaaS) Affiliate	Extortion â€“ Business Disruption	Encrypt critical file servers and BCPs to extort the institution	Initial Access Broker, Assumed Breach, Fast Encryption Payload

2.1 Digital Chain of Evidence

Artifacts produced during this engagement follow a cryptographically-verifiable lifecycle.

LIFECYCLE PHASE	VALIDATION METHOD
Payload & Exploit Transmission	Zero-Knowledge End-to-End Encryption (E2EE)
Exfiltrated Data Storage	Ephemeral Air-Gapped Analysis Environment (256-bit AES)
Red Team Telemetry Retention	Secure SOC Aggregation (Strict 30-Day Limit)
Artifact Destruction	NIST 800-88 Compliant Cryptographic Wipe

2.2 Data Sovereignty & Residency

To adhere to regulatory data protection requirements, the following residency rules apply to all engagement artifacts.

FRAMEWORK	RESIDENCY MANDATE
DORA	All TLPT evidence and reporting artifacts must remain strictly within EU boundaries or approved adequate jurisdictions. Cloud storage requires EU-based tenants under GDPR compatibility.
FRB	Federal regulatory artifacts and all supporting working papers must be accessible on-shore within the United States and subject to Federal Reserve examination.
HKMA	Assessment data and execution artifacts should be stored locally in Hong Kong in accordance with HKMA guidelines and the Personal Data (Privacy) Ordinance (PDPO).
PRA	All testing artifacts, raw execution logs, and threat intelligence reports must remain strictly within the United Kingdom. Cross-border data transfer requires explicit PRA approval.
MAS	Financial data and all assessment details must comply with the Singapore PDPA and MAS Outsourcing Guidelines. On-shore processing is strongly preferred; offshore processing requires MAS notification.

2.3 Regulator Audit & Access Rights

The following audit rights and access privileges are contractually granted to the respective regulatory bodies.

REGULATOR	ACCESS RIGHTS
DORA	European Supervisory Authorities (ESAs) — EBA, ESMA, and EIOPA — must have full, unrestricted, and on-demand access to all TLPT results, threat intelligence profiles, and remediation evidence.
FRB	Federal Reserve examiners possess unrestricted rights to review all working papers, final security deliverables, and management responses regardless of third-party engagement.
HKMA	HKMA retains the right to directly review threat intelligence models, execution logs, and remediation plans. Institutions must notify HKMA of any critical vulnerabilities discovered during iCAST.
PRA	PRA and FCA maintain joint audit rights over the testing methodology, control mappings, and all CBEST deliverables. CREST certification of the service provider is a regulatory prerequisite.
MAS	MAS requires immediate notification of any critical vulnerabilities and retains the right to independently audit all VAPT reports, Red Team logs, and remediation evidence.

Operational Team Governance

PART II.A: TEAM STRUCTURE

White Team & Control Group Structure

In accordance with intelligence-led frameworks (CBEST/iCAST), the engagement must be overseen by a strictly segregated Control Group to ensure operational safety without alerting the defensive Blue Team.

GOVERNANCE BODY	REGULATORY RESPONSIBILITY	CLEARANCE LEVEL
The White Team	Engagement sponsors holding the emergency Kill-Switch. Responsible for defining the Critical Business Services (CBS) and Impact Tolerances.	Full Knowledge
The Control Group	A trusted subset of the client's internal IT/Security team who monitor the engagement for safety but do not participate in defense.	Full Knowledge
The Blue Team	The operational SOC and incident responders who must defend the network as if under a real attack.	Zero Knowledge
Threat Intel Provider	Independent vendor supplying the threat landscape profiles and attack scenarios to the Red Team.	Execution Phase
Covert Red Team	The execution unit simulating the Threat Actor's TTPs against the CBS.	Execution Phase

Rules of Engagement & Operational Safety

Rules of Engagement Baseline

The following operational safety constraints govern all technical execution activities.

CONTROL	AUTHORIZED CONSTRAINT
Testing window	09:00 - 17:00 GMT
Blackout dates	Q4 Freeze (Nov 15 - Jan 5)
Emergency stop contact	**Global CISO & White Team Lead (+1 555-0199)**
Authorized source IPs	198.51.100.0/24 (Red Team Infrastructure)

Emergency Kill-Switch Protocol

⚠ MANDATORY STOP CONDITIONS:

- Stop immediately if any production business service degrades or becomes unavailable.
- Stop if unexpected access to live customer data is achieved.
- Stop on direct verbal or written instruction from the White Team or Client Exec Sponsor.
- Document last action, affected target, timestamp, evidence state, and restart condition before any resumption.

Attack Primitives Matrix

The following operational boundaries legally define the authorized scope of Red Team actions against the financial infrastructure.

ATTACK VECTOR / PRIMITIVE	AUTHORIZATION	CONSTRAINTS & CONDITIONS
Spearphishing & Social Engineering	ALLOWED	Pre-approved lures only; no harvesting of real user credentials.
Assumed Breach / Internal Lateral Movement	ALLOWED	Standard stealth TTPs within explicitly defined CBS targets.
C2 Infrastructure & Implant Deployment	ALLOWED	Simulated payloads only; no real malware dropped to disk.
Core Banking API Exploitation	RESTRICTED	Requires explicit White Team written go-ahead before live exploitation.
SWIFT Gateway Interaction	RESTRICTED	Read-only reconnaissance only unless explicitly authorized in writing.
Physical Premise Tailgating / Intrusion	PROHIBITED	Physical intrusion is strictly out of scope for this TLPT engagement.
Volumetric Denial of Service (DoS/DDoS)	PROHIBITED	All network stress testing is strictly forbidden.
Actual Data Deletion / Ransomware Execution	PROHIBITED	No actual data destruction under any circumstances.

Critical Business Services & Impact Tolerance

PART II.C: CBS IMPACT TOLERANCE

Critical Business Services (CBS) Scope

In accordance with DORA and CBEST, the engagement scope is defined by Critical or Important Functions (CIFs) and their maximum impact tolerances.

CBS ID	BUSINESS SERVICE	UNDERLYING TECHNOLOGY STACK	MAX TOLERABLE DOWNTIME	DATA CLASSIFICATION
CBS-001	SWIFT Payment Gateway Processing	Hybrid Cloud / On-Premise Mainframe	RTO < 4 Hours	Tier 1 - Systemic Critical
CBS-002	Core Retail Banking API Services	AWS Kubernetes Cluster (eu-west-1)	RTO < 1 Hour	Tier 1 - High Priority
CBS-003	Institutional FX Trading Platform	Co-location Data Centre / On-Premise	RTO < 30 Minutes	Tier 1 - Systemic Critical

Access & Test Data Readiness

> Standard testing prerequisites apply: Client must provide stable network access (VPN/Jump host), valid application credentials (min. 2 per role), and any required API documentation prior to the start of the testing window.

Third-Party ICT Supply Chain Scope

PART II.D: THIRD-PARTY RISK

Third-Party ICT Dependency Register

> No third-party ICT dependencies or hosted environments have been declared in scope. Testing is restricted to first-party infrastructure.

Technical Scope of Work

TI-PHASE — **Targeted Threat Intelligence Gathering**

Formally scoped intelligence gathering phase designed to identify threat actors, define attack scenarios, and produce the Threat Intelligence Profile required before Red Team execution.

Allocated Schedule: 15 Days

RT-COVERT — **Covert Red Team Execution**

Intelligence-led, objective-based penetration testing executing the scenarios defined in the TI-PHASE. Includes stealth, evasion, and assumed-breach scenarios against core financial systems.

Allocated Schedule: 40 Days

PT-REPLAY — **Purple Team Replay Exercises**

Collaborative replay of Red Team attack chains alongside the defensive Blue Team to validate SOC detections, incident response capabilities, and SIEM rule effectiveness.

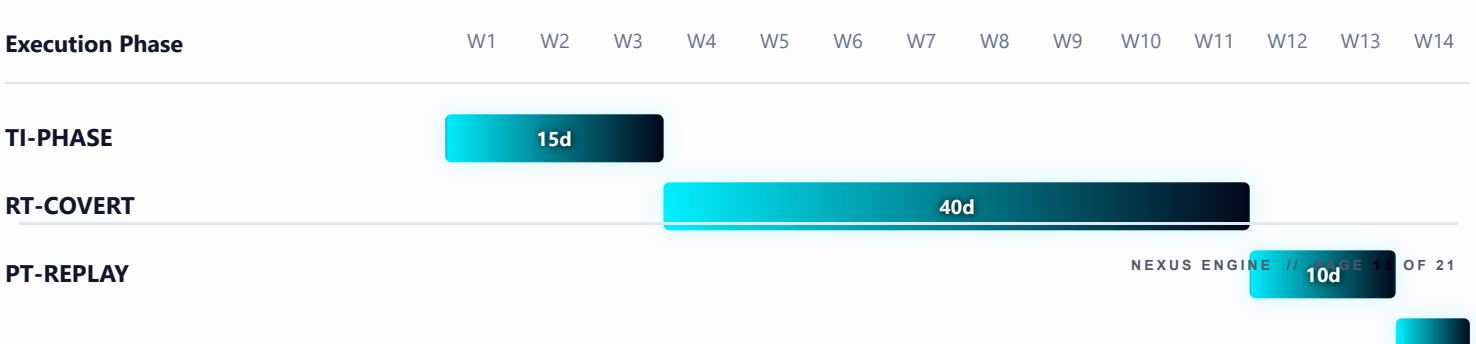
Allocated Schedule: 10 Days

IR-VALIDATION — **Incident Response & Crisis Validation**

Executive tabletop and crisis management simulation based on the findings from the Red Team execution to validate Board-level incident response maturity.

Allocated Schedule: 5 Days

Execution Timeline (Gantt)



Financial Control Mapping (Omni Matrix)

PART III.B: OMNI MATRIX

Financial Control Mapping (Omni Matrix)

The following TLPT-specific financial controls are in scope for the selected execution modules, mapped to their regulatory article references.

CONTROL ID	CONTROL NAME	FRAMEWORK	REGULATORY REFERENCE	IMPACT RATING
CB_01	Core Banking Network Segmentation	DORA	Art. 24 (TLPT)	**Critical**
CB_02	Retail Payment Infrastructure Isolation	DORA	Art. 26 (ICT Resilience)	**Critical**
SW_01	SWIFT Gateway Network Isolation	PRA CBEST	Objective A – Segregation	**Critical**
SW_02	SWIFT Messaging Integrity Validation	PRA CBEST	Objective B – Data Integrity	**Critical**
IAM_01	Privileged Access Management (PAM)	FRB	SR 13-1 – Access Control	**High**
IAM_02	Service Account Credential Hygiene	MAS TRM	Section 12.3 – IAM	**High**
IAM_03	Multi-Factor Authentication Enforcement	MAS TRM	Section 12.4 – Authentication	**High**
TI_01	Threat Intelligence Profile Development	HKMA iCAST	CFI 2.0 – TI Framework	**High**
TI_02	Threat Actor Attribution & Profiling	PRA CBEST	CBEST TI Module	**High**
TI_03	Attack Scenario Development (MITRE ATT&CK)	HKMA iCAST	CFI 2.0 – Scenario Modelling	**High**
TI_04	Threat-Led Defense Posture Assessment	HKMA iCAST	CFI-2 – Posture Review	**High**
IR_01	Active Incident Response Capabilities	DORA	Art. 26 – Crisis Management	**Medium**
IR_02	Executive Crisis Management Simulation	PRA CBEST	CBEST – Closure Report	**Critical**
IR_03	SOC Detection & SIEM Validation	MAS TRM	Section 13 – Incident Response	**High**
IR_04	Purple Team Replay & Remediation Verification	FRB	SR 11-7 – Model Validation	**Medium**
DR_01	Disaster Recovery Plan Validation	DORA	Art. 11 – Business Continuity	**Critical**
DR_02	RTO / RPO Objective Testing Under Load	FRB	SR 13-1 – Continuity	**High**
API_01	Open Banking API Security Boundary	MAS TRM	Section 12.1 – API Controls	**High**
CLD_01	Cloud Workload Lateral Movement Detection	DORA	Art. 30 – ICT Third-Party Risk	**High**

RACI Responsibility Assignment Matrix

Defines who is Responsible, Accountable, Consulted, and Informed for each TLPT activity across all parties.

ACTIVITY	THREAT INTEL PROVIDER	COVERT RED TEAM LEAD	CLIENT WHITE TEAM	CLIENT CONTROL GROUP	CLIENT SECURITY OPS (SOC)	CLIENT EXEC SPONSOR / CISO
Targeted Threat Intelligence Gathering	R	C	A	I	I	I
Attack Scenario & TTP Development	R	C	A	I	I	I
Critical Business Service (CBS) Declaration	I	I	A	C	C	R
Regulator & Scope Notification	I	C	A	I	I	R
White Team Briefing & Kill-Switch Assignment	I	C	R	C	I	A
Covert Red Team Execution (TLPT)	C	R	A	I	I	I
Emergency Kill-Switch Activation	I	C	R	C	I	A
Purple Team Replay Exercises	C	R	I	I	A	I
SOC Detection Rate Validation	I	C	A	C	R	I
Executive Crisis Management Tabletop	I	C	A	I	I	R
Remediation Planning & Sign-off	I	C	C	I	R	A
Regulator Artifact Submission	C	C	I	I	R	A

Regulatory Deliverables Schedule

The following reports and evidence logs are contractually required to satisfy the loaded regulatory frameworks.

REGULATORY BODY	MANDATORY DELIVERABLE ARTIFACT
Digital Operational Resilience Act (DORA)	Asset Register & CBS Map
Digital Operational Resilience Act (DORA)	ICT Risk Register
Digital Operational Resilience Act (DORA)	Threat Intelligence Profile
Digital Operational Resilience Act (DORA)	TLPT Test Plan (Pre-Execution)
Digital Operational Resilience Act (DORA)	TLPT Execution Report
Digital Operational Resilience Act (DORA)	Remediation Plan & Timeline
Digital Operational Resilience Act (DORA)	Third-Party ICT Risk Assessment
Federal Reserve Board (FRB) Supervision	Independent Technology Review Report
Federal Reserve Board (FRB) Supervision	Management Response & Remediation Plan
Federal Reserve Board (FRB) Supervision	Prior Findings Remediation Evidence
Federal Reserve Board (FRB) Supervision	FFIEC CAT Baseline Assessment
Hong Kong Monetary Authority (HKMA) iCAST	CAF Self-Assessment Report
Hong Kong Monetary Authority (HKMA) iCAST	Threat Intelligence Profile (TI-PHASE Output)
Hong Kong Monetary Authority (HKMA) iCAST	iCAST Execution Log
Hong Kong Monetary Authority (HKMA) iCAST	Closure Report & Control Effectiveness Summary
Hong Kong Monetary Authority (HKMA) iCAST	Remediation Plan
Prudential Regulation Authority (PRA) CBEST	Targeted Threat Intelligence Report (TTIR)
Prudential Regulation Authority (PRA) CBEST	CBEST Test Plan
Prudential Regulation Authority (PRA) CBEST	Red Team Execution Report
Prudential Regulation Authority (PRA) CBEST	Control Effectiveness Summary
Prudential Regulation Authority (PRA) CBEST	Closure Report (PRA/FCA Submission)
Monetary Authority of Singapore (MAS) TRM	VAPT Report
Monetary Authority of Singapore (MAS) TRM	Red Team Execution Log
Monetary Authority of Singapore (MAS) TRM	Root Cause Analysis Report
Monetary Authority of Singapore (MAS) TRM	Remediation Status Register
Monetary Authority of Singapore (MAS) TRM	Board Cyber Risk Report

Quality Assurance & Peer Review

Formal Quality Assurance Gate

Based on the selected regulatory frameworks and execution modules, the following QA routing is algorithmically enforced.

REQUIRED QA LEVEL: TLPT Qualified Red Team Reviewer

Mandatory Threat-Led Penetration Testing (TLPT) review gate. Evidence and kill-chain paths must be validated by a certified Red Team peer reviewer before report release.

Verification & Sign-off

PART V: AUTHORIZATION

NEXUS SEAL

Executive Sponsor Approval

Lead Strategic Provider

Engagement Sign Off & Authorization

By signing below, the parties confirm that this Nexus Scoping Document has been reviewed and is accepted as the binding scope of work for the defined Threat-Led Penetration Testing engagement. This document satisfies the engagement scoping requirements for the active regulatory frameworks: **DORA, PRA CBEST, HKMA iCAST, FRB, and MAS TRM**.

SIGNATORY ROLE	FULL NAME	SIGNATURE	DATE
Client Executive Sponsor / CISO			
Client White Team Lead			
Red Team Lead (Provider)			
Threat Intelligence Lead (Provider)			

✓ **Document Control:** This document is classified **RESTRICTED**. Distribution is limited to parties named in the White Team register. Regulatory bodies retain audit rights as defined in Part II of this document.